soken

Application security review

Arvo Protocol

Commit `e6ab45a`, Next.js application

21 October 2026

0	0	0	3	7
CRITICAL	HIGH	MEDIUM	LOW	INFORMATIONAL

PREPARED BY SOKEN LTD	CLIENT Arvo Protocol, github.com/arvoprotocol
REPOSITORY AND COMMIT github.com/arvoprotocol/arvo-app, e6ab45a	NETWORK Next.js application
SCOPE A Next.js application: its on-chain transaction paths, its complete HTTP API, its front end, configuration and dependencies	FINDINGS 0 Critical, 0 High, 0 Medium, 3 Low, 7 Informational
CURRENT CODE Commit `9e9ce9b`; response headers of both public hosts read 2026-10-21	DATE 21 October 2026

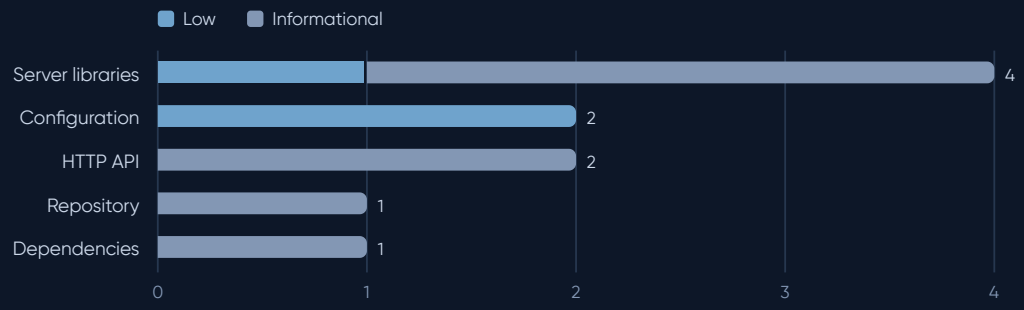
01 Summary

0	0	0	3	7
CRITICAL	HIGH	MEDIUM	LOW	INFORMATIONAL

22	7	15
API ROUTES REVIEWED	PUBLIC ROUTES REVIEWED	ADMIN ROUTES, ALL GATED

0	0	0
REACHABLE XSS SINKS	SERVER SECRETS REACHING CLIENT	PRODUCTION DEPENDENCY ADVISORIES

Figure 1. Findings by component



ID	TITLE	COMPONENT	SEVERITY
APS-L1	Content-Security-Policy omits default-src and script-src	Configuration	LOW
APS-L2	Database client module lacks the server-only guard	Server libraries	LOW
APS-L3	HSTS without includeSubDomains or preload	Configuration	LOW
APS-I1	Signup response allows account enumeration	HTTP API	INFORMATIONAL
APS-I2	Editor backup file tracked in version control	Repository	INFORMATIONAL
APS-I3	Central proxy handles host routing but not authentication	HTTP API	INFORMATIONAL
APS-I4	One secret signs both the admin session and the app-access cookie	Server libraries	INFORMATIONAL
APS-I5	High advisories confined to the development toolchain	Dependencies	INFORMATIONAL
APS-I6	Same-origin check reads a spoofable forwarded header	Server libraries	INFORMATIONAL
APS-I7	Admin draft error returns the raw error message	Server libraries	INFORMATIONAL

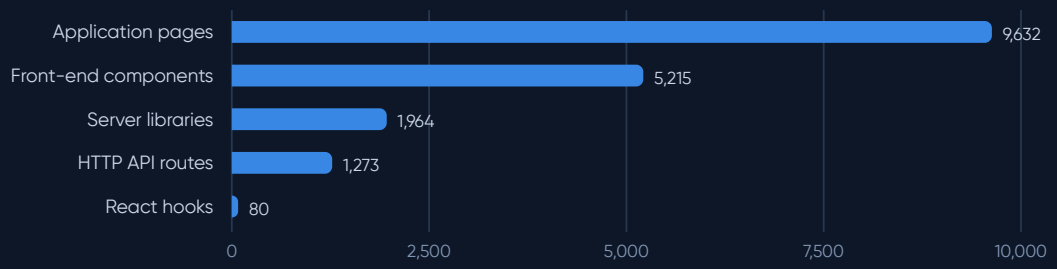
02 Scope

AREA	PATH	NSLOC	DEPTH OF REVIEW
Application pages	`src/app (excl. api)`	9,632	Surface: script-injection sinks, secret isolation, wallet flow

SOKEN LTD | 86-90 Paul Street, London EC2A 4NE | Companies House 15253906
soken.dev | x.com/soken_team | t.me/soken_ai | linkedin.com/company/soken-llc | github.com/Soken-LTD

Front-end components	`src/components`	5,215	Surface: injection sinks, dynamic markup, data trust
Server libraries	`src/lib`	1,964	Full: auth, sessions, mail, support, request security
HTTP API routes	`src/app/api`	1,273	Full: every route handler
React hooks	`src/hooks`	80	Full: wallet connection and admin data
Total		**18,164**	

Figure 2. Size of the code in scope, source lines without comments and blank lines

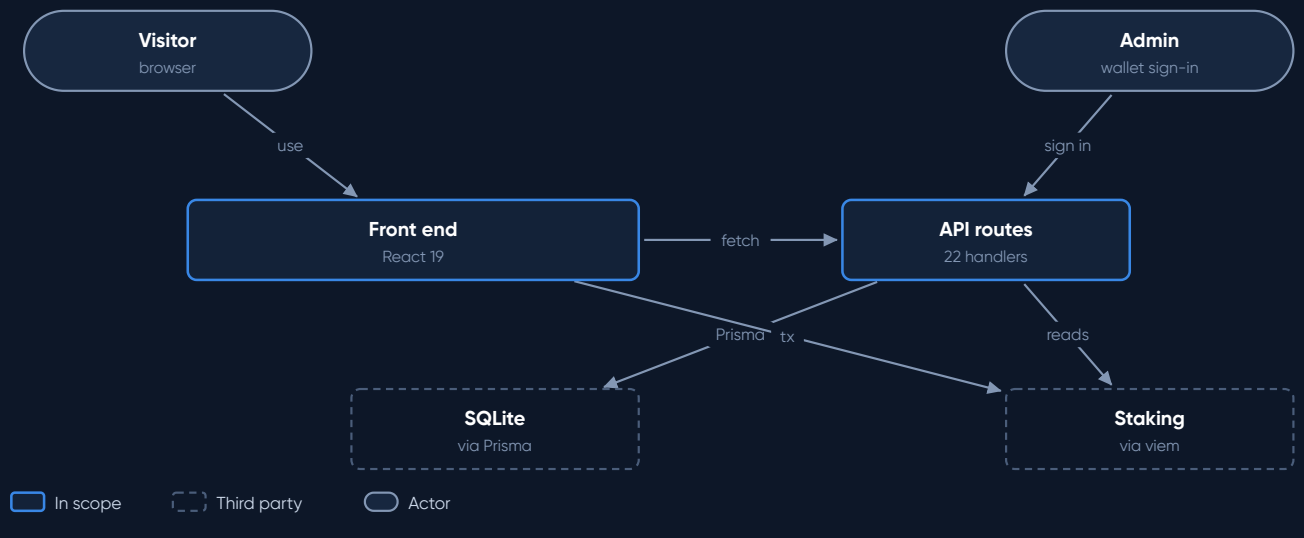


Out of scope

ITEM	REASON
Smart contracts (`arvo-contracts`)	Covered by the separate staking security review
A running deployment	A static source review. The only live interaction is an unauthenticated read of the response headers of `arvoprotocol.com` and `app.arvoprotocol.com` on 2026-10-21
Third-party services (wallet, RPC, SMTP providers)	External to the application source

03 Architecture and privileged roles

Figure 3. Application surfaces and their dependencies



Privileged roles

PRINCIPAL	SOURCE	TYPE	POWER
Admin	`ADMIN_WALLET_ADDRESS`	Single EOA	The admin console: projects, partners, support, vault drafts and outbound email
App access	`APP_ACCESS_PASSWORD`	Shared secret	Opens the gated app surface, for example support and acquisition links
Public	none	Unauthenticated	Contact form, signup, partner token lookup and published project images

OBSERVATION	DETAIL
Admin model	A single configured wallet address. A 65-byte EOA signature over a one-time challenge is required; contract (ERC-1271) signatures are rejected by length and by the verifier
Session	An HMAC-signed cookie, httpOnly, secure and SameSite strict, with a 12-hour expiry and server-side revocation
Enforcement	Authorization is enforced in each route handler. There is no central middleware; every route was checked individually and all were gated

04 Method and severity scale

STEP	WORK DONE
Transaction paths	Reading of wallet connection, transaction construction and signing, and the reward and treasury flows that move or authorise funds
HTTP API	Every route handler read for authorization, input validation, injection, enumeration, path handling and rate limiting
Authentication	The admin challenge, signature verification and session, and the application-access gate
Front end and configuration	Client components for script-injection sinks and server-secret isolation, and the configuration for security headers
Dependencies	The production and development dependency manifest checked against known advisories from the lockfile

Severity scale

SEVERITY	MEANING
CRITICAL	Loss or permanent freeze of user funds, or full administrative takeover, with no unusual precondition
HIGH	Loss of funds, account takeover or data exposure under realistic preconditions
MEDIUM	Limited loss or exposure that needs an uncommon but plausible condition
LOW	A departure from the specification or hardening baseline with a bounded effect
INFORMATIONAL	Hardening, hygiene and defence-in-depth notes with no reachable exploit

05 Findings

Low

APS-L1 Content-Security-Policy omits default-src and script-src

LOW

COMPONENT	LOCATION	CATEGORY
Configuration	`next.config.ts:18`	Security headers

DESCRIPTION

The response Content-Security-Policy sets `base-uri`, `object-src`, `frame-ancestors` and `form-action` but no `default-src` and no `script-src`. Without those directives the policy places no restriction on where scripts may load from or execute. The framework guide for this version ships a baseline policy that includes `default-src 'self'`, a `script-src` and `upgrade-insecure-requests`.

IMPACT

Defence-in-depth only. The review found no reachable script-injection sink: there is no `dangerouslySetInnerHTML`, no `eval`, and URL-derived values are validated. On a wallet-connecting application a restrictive `script-src` is still a valuable second line against a future injection.

RECOMMENDATION

Add `default-src 'self'` and an explicit `script-src 'self'` with any required origins, and `upgrade-insecure-requests`. A nonce-based policy applied in middleware is the framework's recommended strict form and would also centralise the per-route authentication noted below.

APS-L2 Database client module lacks the server-only guard

LOW

COMPONENT	LOCATION	CATEGORY
Server libraries	`src/lib/prisma.ts:1`	Secret isolation

DESCRIPTION

The Prisma client module does not import `server-only`. Other server modules that read secrets do carry the guard. No client component imports the Prisma module today, so nothing leaks; the guard is absent as build-time enforcement against a future accidental client import.

IMPACT

No current exposure. A later client import of this module would pull the database connection into the client bundle without a build error to stop it.

RECOMMENDATION

Add `import "server-only";` at the top of the module.

APS-L3 HSTS without includeSubDomains or preload

LOW

COMPONENT	LOCATION	CATEGORY
Configuration	`next.config.ts:19`	Security headers

DESCRIPTION

In production the Strict-Transport-Security header is `max-age=31536000` with neither `includeSubDomains` nor `preload`.

IMPACT

Subdomains are not brought under HSTS, and the domain is not eligible for the preload list.

RECOMMENDATION

Add `includeSubDomains; preload` once every subdomain is served over HTTPS.

Informational

APS-I1 Signup response allows account enumeration

INFORMATIONAL

COMPONENT	LOCATION	CATEGORY
HTTP API	`src/app/api/platform/signup/route.ts`	Information disclosure

DESCRIPTION

The signup response distinguishes an existing account from a new one. The route is same-origin and rate-limited, and the data is low sensitivity.

IMPACT

An attacker who already reaches the endpoint can test whether a given identifier is registered.

RECOMMENDATION

Return a uniform response whether or not the account already exists.

APS-I2 Editor backup file tracked in version control

INFORMATIONAL

COMPONENT	LOCATION	CATEGORY
Repository	`src/app/page.tsx.save`	Repository hygiene

DESCRIPTION

An editor backup file is committed to the repository, confirmed present in the tracked file list.

IMPACT

A stale copy of source sits in the repository and ships with clones.

RECOMMENDATION

Remove the file and add `*.save` to `.gitignore`.

APS-I3 Central proxy handles host routing but not authentication

INFORMATIONAL

COMPONENT	LOCATION	CATEGORY
HTTP API	`src/proxy.ts`	Access control

DESCRIPTION

The application has a central request proxy at `src/proxy.ts`, the Next.js 16 replacement for the middleware file, with a matcher that runs it on every non-asset request. It performs host routing between the site and app domains, rejects or redirects on the wrong host, and sets cache and robots headers. It does not perform authentication. Authentication is enforced in each route handler. The route review found every protected route gated and no bypass, so there is no reachable gap; the central layer simply does not carry the auth check.

IMPACT

No reachable gap today. A future route added without its own guard would not be caught by a central authentication check, since the existing proxy does not perform one.

RECOMMENDATION

Extend the existing `src/proxy.ts` to enforce authentication on the admin and gated paths as a second layer, and carry the nonce-based policy from APS-L1 there.

APS-I4 One secret signs both the admin session and the app-access cookie

INFORMATIONAL

COMPONENT	LOCATION	CATEGORY
Server libraries	`src/lib/admin/session.ts:17`, `src/lib/app-access/session.ts:20`	Key management

DESCRIPTION

`ADMIN_SESSION_SECRET` is used to sign both the admin session and the application-access cookie.

IMPACT

Rotating the secret invalidates both surfaces at once, and a weakness in one context affects the other.

RECOMMENDATION

Use a separate secret for each surface.

APS-I5 High advisories confined to the development toolchain

INFORMATIONAL

COMPONENT	LOCATION	CATEGORY
Dependencies	`package.json` devDependencies	Dependencies

DESCRIPTION

An audit of the lockfile reports five high advisories, all within the development dependency chain. The production dependency set reports zero advisories at any severity.

IMPACT

No production runtime exposure. The advisories affect developer and build-time tooling only.

RECOMMENDATION

Update the development toolchain when convenient to clear the advisories.

APS-I6 Same-origin check reads a spoofable forwarded header

INFORMATIONAL

COMPONENT	LOCATION	CATEGORY
Server libraries	`src/lib/security/request.ts:16`	Request security

DESCRIPTION

The same-origin check compares the Origin header host against a target host taken from `x-forwarded-host`, a header a client or intermediary can set. The binding gate is separate and sound: the Origin must be one of the configured allowlisted origins and the request must not be cross-site by `sec-fetch-site`. The forwarded header only affects a secondary host-equality check that can pass only when the Origin is already allowlisted.

IMPACT

No same-origin bypass: an attacker cannot make a non-allowlisted Origin pass, because the allowlist test on the browser-set Origin header is independent of the forwarded header. The concern is the use of a spoofable header inside a security comparison.

RECOMMENDATION

Derive the expected host from server configuration rather than from `x-forwarded-host`, or drop the host-equality branch and rely on the Origin allowlist and `sec-fetch-site`.

APS-I7 Admin draft error returns the raw error message

INFORMATIONAL

COMPONENT	LOCATION	CATEGORY
Server libraries	`src/lib/admin/vault-draft-api.ts:28`	Information disclosure

DESCRIPTION

For an unexpected error that is neither a request error nor a known database code, the draft handler returns `error.message` to the caller. The handler is reached only after the admin session gate, so the message is seen only by an authenticated administrator, and most errors on this path are intentional validation messages.

IMPACT

Bounded information disclosure to an already-authenticated admin. A generic internal error message could reach that admin rather than a neutral string.

RECOMMENDATION

Return a neutral message for unexpected errors and log the detail server-side.

06 Code at commit 9e9ce9b

FINDINGS AGAINST THE CODE AT 9E9CE9B

FINDING	SEVERITY	AT 9E9CE9B
APS-L1	LOW	`src/lib/security/csp.ts` builds a per-request nonce policy: `default-src 'self'`, `script-src 'self' 'nonce' 'strict-dynamic'`, `script-src-attr 'none'`, `object-src 'none'`, `frame-ancestors 'none'`, `base-uri 'self'`, `upgrade-insecure-requests`; `unsafe-eval` only in development. Both public hosts serve it
APS-L2	LOW	`src/lib/prisma.ts` opens with `import "server-only"`
APS-L3	LOW	Both hosts send `max-age=31536000; includeSubDomains`; preload is not enabled
APS-I1	INFORMATIONAL	Signup returns `{ok: true}` for a new and for an existing address
APS-I2	INFORMATIONAL	`*.save` is in `.gitignore`; no `.save` file is tracked
APS-I3	INFORMATIONAL	Per-route guards; `src/proxy.ts` applies the nonce policy. `tooling/audit_auth_checks.cjs` runs in the security workflow on every push and pull request and exercises the admin same-origin gate, the challenge, signature, replay and expiry checks, session revocation and the wallet challenge; the gate on each of the twenty-two routes is covered by reading, not by that script
APS-I4	INFORMATIONAL	`APP_ACCESS_SESSION_SECRET` is read independently of `ADMIN_SESSION_SECRET`, with no fallback
APS-I5	INFORMATIONAL	The production dependency audit reports 0 advisories
APS-I6	INFORMATIONAL	`src/lib/security/request.ts` checks the browser `Origin` against an allowlist and binds admin mutations to the application origin; forwarded host headers are not consulted
APS-I7	INFORMATIONAL	Typed validation messages; other errors return a neutral text and the detail is logged server side

REPOSITORY	COMMIT OF THE FINDINGS	COMMIT OF THIS SECTION	BRANCH
arvo-app	e6ab45a	9e9ce9b	audit-remediation-20261019-085800

RESPONSE HEADERS OF THE PUBLIC HOSTS, READ 2026-10-21

HEADER	ARVOPROTOCOL.COM	APP.ARVOPROTOCOL.COM
Content-Security-Policy	Full nonce policy, one header; the nonce differs between two consecutive requests	Full nonce policy, one header; the nonce differs between two consecutive requests
Script tags carrying the header nonce	12 of 12	19 of 19
X-Frame-Options	`DENY`, once	`DENY`, once
X-XSS-Protection	absent	absent
Strict-Transport-Security	`max-age=31536000; includeSubDomains`	`max-age=31536000; includeSubDomains`
X-Content-Type-Options, Referrer-Policy	`nosniff`, `same-origin`, once each	`nosniff`, `same-origin`, each sent twice with the same value; no effect on enforcement
Cache-Control	`private, no-store`, once	`private, no-store` and `no-transform`, two headers; the browser combines them, no effect
Permissions-Policy	camera, microphone, geolocation and payment denied	camera, microphone, geolocation and payment denied

Unauthenticated GET of `/` on each host, two requests each, over HTTPS.

07 Verification of the clean surface

SURFACE	RESULT
Secret isolation	Every server module that reads a secret carries `server-only`; no server secret is imported by a client component. The six public `NEXT_PUBLIC_` values are all non-secret
API authorization	All twenty-two route handlers enforce the correct gate: fifteen admin routes behind `getAdminSession`, seven public routes behind an app-access or token check where required
Signature verification	Admin login accepts only a 65-byte EOA signature (a 130-hex check) over a one-time challenge, verified with the EOA verifier; contract signatures are rejected by both length and verifier
Path handling	The image route serves only a filename matching an anchored identifier pattern, applied before any file read, so directory traversal is not reachable
Injection	The single raw SQL statement is a parameterized tagged template; no command is executed on user input; there is no server-side fetch of a user-supplied URL
Cross-site scripting	No `dangerouslySetInnerHTML` and no `eval`; values taken from the URL are validated before use

08 Testing

CHECK	ITEMS	CLEAN	FLAGGED
Production dependency advisories (lockfile)	15	15	0
All dependency advisories, including development	26	21	5

TOPIC	OBSERVATION
Dependency audit	The production dependency set reports zero advisories at any severity. Including development dependencies, five high advisories appear, all within the build and lint toolchain and not shipped at runtime
Repository auth test	The repository ships an offline auth test covering thirteen scenarios of the admin challenge, signature and session. It needs its dependencies and a database fixture to run; those were not present, so the scenarios were confirmed by reading the source rather than by execution
Running instance	No live deployment was exercised. The findings are from static source review; a dynamic test against a running instance is a separate exercise

09 Review coverage

AREA	CHECKED	RESULT
Transaction paths	Wallet connect, transaction construction and signing, reward and treasury flows	Addresses read on chain, role-gated and simulated before sending, no unbounded approvals
API authorization	All twenty-two route handlers	Every route gated; fifteen admin behind `getAdminSession`, seven public behind app-access or a token
Authentication	Admin challenge, signature and session	One-time 32-byte nonce, 5-minute expiry, address and domain bound, EOA signature, HMAC session httpOnly and strict
Injection and path	Raw SQL, command, server-side fetch, file path	Single raw SQL parameterized; no command execution; no fetch of a user URL; image path identifier-gated
Secret isolation	Server environment in the client bundle	Every server module carries `server-only`; no secret reaches the client
Cross-site scripting	Injection sinks and dynamic markup	No raw-markup sink, no `eval`, URL inputs validated
Security headers	The response headers in configuration	Frame, content-type, referrer, permissions and HSTS set; CSP with a per-request nonce `script-src` on both hosts
Dependencies	Production and development advisories	Production clean; five high advisories confined to the development toolchain

10 Disclaimer

This report was prepared by SOKEN LTD (Companies House 15253906). It records a security review of the application source at commit e6ab45a, the state of the source at commit 9e9ce9b and the response headers of the two public hosts, dated 21 October 2026. The review is a static source review of the transaction paths, the HTTP API, the front end, the configuration and the dependency manifest. It is a point-in-time assessment and is not a guarantee that the application is free of defects, nor an endorsement of the project or its operators. The only live interaction was an unauthenticated read of the response headers of the two public hosts on 21 October 2026; no credentials or transactions were used, and the smart contracts are covered by a separate report. Nothing in this document is financial, investment or legal advice.

SOKEN LTD | 86-90 Paul Street, London EC2A 4NE | Companies House 15253906
soken.dev | x.com/soken_team | t.me/soken_ai | linkedin.com/company/soken-llc | github.com/Soken-LTD